



SEF® Lean Version

Organisational Accountability Structure

DISCLAIMER

This document is provided 'AS-IS' and its contents may change over time and without notice. Any examples used are for illustration only and are fictitious. No real association is intended or should be inferred. This publication does not constitute an endorsement of any product described.

Technognomi Ltd expressly disclaims any liability, which may arise in any manner and to any party through the publication of this document and application of the method contained. Any party acting for or failing to act as a result of this document assumes full responsibility for any use made of the information contained herein.

The direct or indirect reference to organisations, products, methods, frameworks, or standards does not imply that they are endorsed or recommended by Technognomi Ltd in preference to others of a similar nature that are not mentioned.

COPYRIGHT

This document is the property of Technognomi Ltd; the contents herein are the intellectual property and copyright of Technognomi Ltd. Disclosure of this document and its contents does not grant or construe and transfer or other rights in relation to Technognomi Ltd intellectual property.

© Copyright 2014+. Technognomi Ltd. All rights reserved.

TRADEMARKS

The SEF® Lean Version, as amended from time to time, is part of the Secure Enterprise Framework®, which is also known as SEF®. The Secure Enterprise Framework® and SEF® were trademarked by the European Union Intellectual Property Office (EUIPO) under Registration Number 017094137. All trademarks or registered trademarks either mentioned or implied are respected.

LICENCE



Except where otherwise indicated, this work is licensed by Technognomi Ltd under the Creative Commons (CC) BY-NC-ND 4.0 licence.

To view a copy of this license, please visit:

<https://creativecommons.org/licenses/by-nc-nd/4.0/>

Anyone wishing to adapt, modify, share, or distribute copies of the SEF® Lean Version for revenue generating purposes or wishing to utilise the method in any other way, must first obtain an appropriate licence from Technognomi Ltd by contacting the company at services@technognomi.com.

All trademark, copyright, or other notices affixed onto the SEF® Lean Version must be reproduced and may not be removed.

READERSHIP

This document is intended for enterprise architects, service architects, business architects, information architects, infrastructure architects, integration architects, security architects, programme managers, and business directors who seek to establish clear accountability across their organisations through structured ownership.

SUGGESTED CITATION

BARUTTIS, A. (2020). *SEF® Lean Version - Organisational Accountability Structure* [PDF]. Release 4.0. Technognomi Ltd.

TABLE OF CONTENTS

AIM.....	5
PURPOSE	5
INTRODUCTION	5
1 ORGANISATIONAL ACCOUNTABILITY GAPS	6
2 ACCOUNTABLE BUSINESS ROLES	7
2.1 ACCOUNTABILITY VS RESPONSIBILITY	7
2.2 METAMODEL.....	7
2.3 BUSINESS ROLES	10
3 BENEFITS	19
GLOSSARY.....	21
REFERENCES.....	22

AIM

The aim of this document is to articulate, in detail, the organisational accountability structure that supports the SEF® Lean Version¹.

PURPOSE

The purpose of this document is to establish the organisational accountability structure of the SEF® Lean Version, defining clear ownership and accountability to support strategic alignment and consistent decision making.

INTRODUCTION

This document consists of three parts. The first part articulates the gaps of organisational accountability. The second part presents the ownership business roles included in the SEF® Lean Version. It articulates how the organisational accountability structure distinguishes accountability from responsibility, describes the metamodel of this structure, and describes the corresponding business roles with their duties. The third part presents the business benefits of implementing and utilising the proposed organisational accountability structure.

¹ The SEF® Lean Version is part of the Secure Enterprise Framework® (SEF®).

1 ORGANISATIONAL ACCOUNTABILITY GAPS

Over the years, it appears that in many organisations, accountability has been conflated with blame and punishment, creating associations with negativity and negligence. This misuse of accountability as a disciplinary mechanism rather than a governance enabler has undermined its value and created resistance to clear accountability structures.

Although some argue this negativity is the primary cause of organisational accountability failures, these negative associations may instead be effects resulting from the challenge of establishing accountability holistically in organisations, which this framework recognises as complex adaptive systems. In addition, and most critically, accountability is frequently confused with responsibility. These terms have fundamentally different meanings that must never be used interchangeably.

Examining the roots of these effects reveals that in traditional contexts, accountability has been applied through ownership, understood as a relationship of possession between an active entity and a passive element within a system. This relationship works effectively in complex systems that comprise tangible and static elements. For example, a large building with apartments, where each apartment is owned by a different legal entity. Ownership in these contexts is straightforward, whereby the owner possesses a tangible and static entity within a complex system, and accountability follows naturally from possession.

However, organisations are complex adaptive systems where most elements are intangible and dynamic. A business service is intangible; it is consumed at the point of production and exists only during delivery. A business process that produces a service is also intangible. Although it may be documented and visualised, it has no physical form. Information assets can be read but are intangible and can be replicated across software systems. These intangible, dynamic elements cannot be owned in the traditional sense of possession because of the adaptive attribute inherent in organisations that also makes complexity dynamic.

This complexity creates fundamental gaps regarding organisational accountability because traditional ownership models assume clear possession of a tangible element, yet most organisational elements are intangible, shared, and dynamic. The relationships between these elements are adaptive, complex, and interconnected. These properties have historically made accountability ambiguous in organisations. The SEF® Lean Version recognises these properties and provides the foundational structure required to understand and manage them, and address the accountability gaps. Building on this structure, it identifies the critical organisational elements and assigns clear boundaries of accountability to designated business roles.

2 ACCOUNTABLE BUSINESS ROLES

Before defining business roles to address accountability and corresponding boundaries, it is imperative to make a distinction between ownership and custodianship, where the former addresses accountability and the latter responsibility. Therefore, a critical distinction must be understood between these two concepts, which form the foundation of effective organisational governance.

2.1 ACCOUNTABILITY VS RESPONSIBILITY

Ownership is characterised by accountability for outcomes. Owners are ultimately answerable for results, whether positive or negative. Accountabilities cannot be delegated by owners; only the responsibilities for executing specific tasks can be assigned to others, who in turn, become custodians. Owners make decisions about what they own and set rules, normally included in policies, that govern how to manage them. When outcomes fall short, owners are held accountable.

Custodianship, by contrast, is characterised by responsibility for daily execution. Custodians perform operational activities that have been delegated by owners. Custodians can be replaced without altering the accountability structure, as accountabilities remain constant regardless of who executes the work. Custodians follow the rules established by owners and execute decisions made by owners or on behalf of owners. When making decisions on behalf of owners, accountability still lies with the owners and not the custodians.

Having addressed these distinctions, ownership business roles need clear boundaries of accountability mapped to an architectural model. Without this mapping, accountability boundaries cannot be defined without creating overlaps and leaving gaps. The SEF® Lean Version maps these roles to the core building blocks contained within the domains and profiles of the architectural model through a metamodel.

2.2 METAMODEL

The accountability structure defines twelve distinct business roles that operate across the organisation, each with clearly defined ownership scope. The accountable roles, illustrated in fig. 1, are defined per profile and domain of the architectural model, as described in the SEF® Lean Version (Baruttis, 2020), and may be mapped to existing roles (e.g., a Finance Director is also the Information Asset Owner for the Financial Information Assets).

Starting with the **structural profile**, a **product owner** operating at the **offering domain** is accountable for one or more business **products**. A business product may include one or more business **goods** or business **services**², or a combination of both. When business products include business services, the product owner ensures products are delivered by designated business services but is not accountable for the operational delivery of those

² The offering domain comprises products, which may be goods, services, or a combination of both. The prefix 'business' is used to prevent ambiguity with equivalent terms used in other contexts. For example, to distinguish a 'business service' from an 'IT service'.

services. To address this scenario, a **service owner** is accountable for one or more business services.

Business goods and business services are delivered by **business processes** operating within the **business domain**. A **business process owner** is accountable for one or more business processes. In turn, business processes are executed by individuals in **business roles** defined within corresponding **business functions**. A **business function owner** is accountable for one or more business functions.

Business roles use **knowledge**, which operates in the **knowledge domain**, to execute business processes. Knowledge is derived from **information** found in discrete **information items**, for which an **information owner** is accountable for one or more of these items. These information items form a **taxonomy group**, which collectively constitutes the **information taxonomy**. Furthermore, an **information asset** may comprise one or more taxonomy groups, where each group comprises one or more **datasets**, consisting of foundational **data**. Then, an **information asset owner** is accountable for one or more information assets.

At the **application domain**, a **system owner** is accountable for **application software**, which manages one or more associated datasets. Furthermore, the system owner is accountable for one or more **IT systems**, operating in the **infrastructure domain**, each hosting one or more applications. Each IT system is housed within one or more **facilities**, operating in the **facility domain**. Consequently, a **facility owner** is accountable for one or more facilities.

As **interfaces** operating in the **interface profile** span business services, business processes, information and data, application software, infrastructure, and facilities, an **interface owner** is accountable for one or more such interfaces operating in each domain of the structural profile. Lastly, at the **security profile**, while **threats** create **inherent security risks**, **security controls** are applied to address these threats. This application mitigates inherent risks, leaving **residual security risks**. Accordingly, a **security control owner** is accountable for one or more such controls.

Finally, when **risks** or **issues** materialise within their respective domains, the aforementioned owners become **risk owners** or **issue owners**, at which point a specific individual is formally assigned to the relevant role.

While all defined owners may delegate duties to custodians, ultimate accountability remains with the respective owner. This distinction is explicitly stated in the accountabilities of each business role.

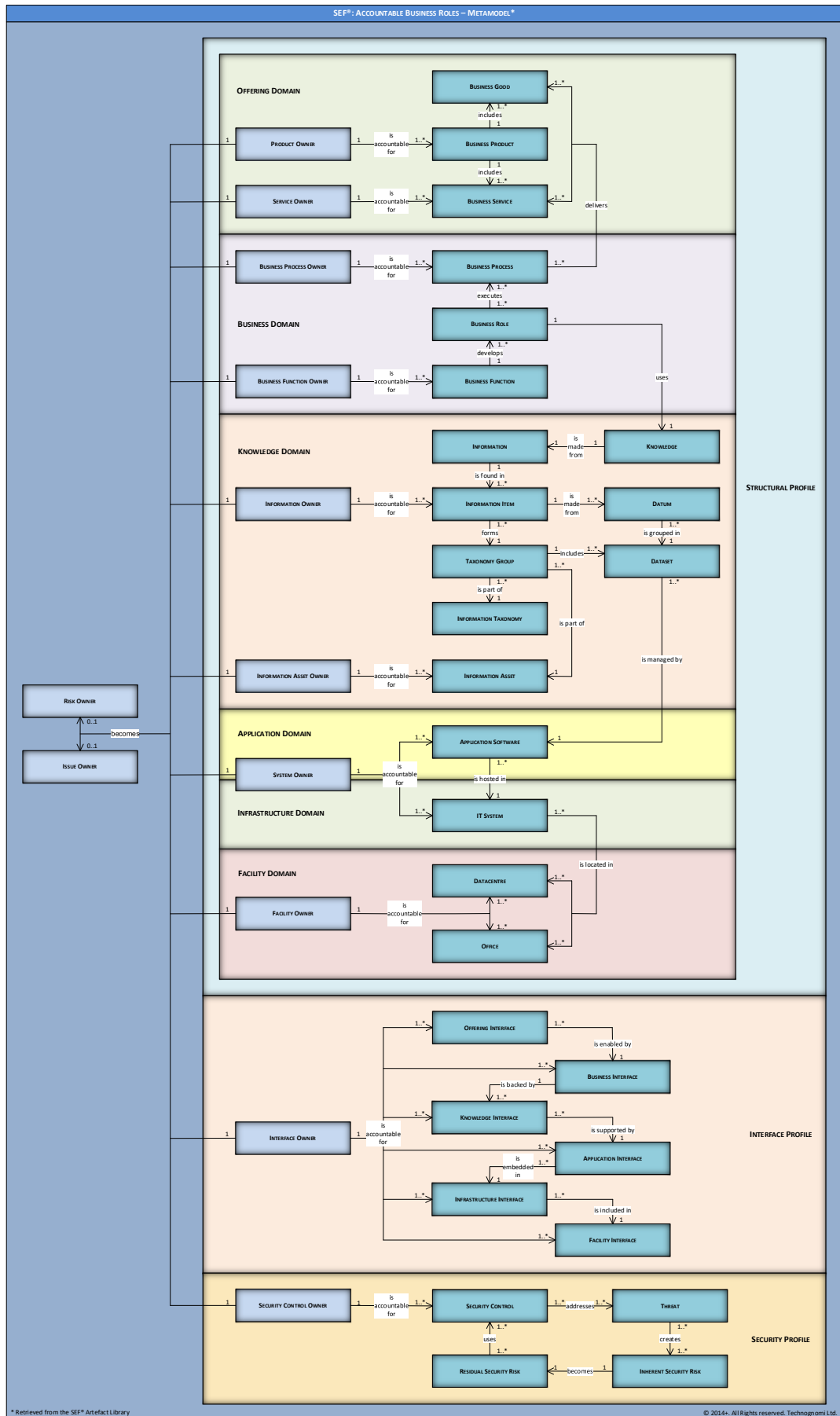


Figure 1. SEF® Lean Version: Accountable Business Roles – Metamodel

2.3 BUSINESS ROLES

The accountability structure of the SEF® Lean Version comprises twelve closely related and interconnected business roles. The duties of these roles explicitly emphasise their scope, and the distinction between accountability and delegated responsibility. A comprehensive breakdown of each role, including its description and specific accountabilities, is presented in table 1.

Business Role	Description	Accountability
Product Owner	The Product Owner is accountable for one or more products offered to customers. A product may consist of goods only (e.g., washing machines), services only (e.g., mortgages), or a combination of both (e.g., software with support). The Product Owner focuses on market strategy, the customer value proposition, product features, and achieving strategic goals (e.g., long-term market competitive advantage) and tactical objectives (e.g., revenue targets in commercial contexts or public value in non-commercial contexts). This accountability extends to all components of the product. Where products include business services, the Product Owner ensures they are delivered by designated business services but is not accountable for their operational delivery.	- Owns one or more designated products. - Ensures the product lifecycle is managed efficiently from inception until retirement. - Ensures the product delivers value and achieves its strategic goals and tactical objectives. - Ensures the product is competitive in its market, where competition is applicable. - Ensures the product achieves viable profit margin, where profit is applicable. - Ensures the product is delivered by designated business services, where applicable. - Ensures the product complies with regulatory and legal requirements. - Approves product features and specifications. - Approves the product transition into market. - Approves changes made to the product offering. - Ensures the product has a Business Continuity Plan (BCP). - Approves the Business Continuity Plan (BCP) of the product. - Ensures the product is validated and meets all defined acceptance criteria before launch. - Delegates responsibilities but not accountabilities. - Becomes the risk owner of market, reputational, and compliance risks affecting the product. - Becomes the issue owner of market, reputational, and compliance issues affecting the product.

Business Role	Description	Accountability
Service Owner	The Service Owner is accountable for one or more business services consumed by external or internal customers. Business services may be delivered individually, bundled as products for external customers, or provided to internal business functions supporting organisational operations. The Service Owner focuses on operational delivery, service effectiveness, service continuity, and achieving operational objectives. Unlike the Product Owner who owns the strategic product bundle, the Service Owner owns the service operational delivery.	- Owns one or more designated business services. - Ensures the business service lifecycle is managed efficiently from inception until disposal. - Ensures the business service achieves its operational objectives. - Ensures the business service complies with relevant regulatory and legal requirements. - Ensures the business service is delivered by designated business processes. - Approves the business service transition into operations. - Approves the changes made to the business service. - Preapproves the shutdown of the business service to support the deployment of security patches or to contain cyberattacks, where the service depends on underlying application software and IT systems. - Ensures the business service is valued in terms of integrity and availability criticality. - Ensures the business service has a Business Continuity Plan (BCP). - Approves the Business Continuity Plan (BCP) of the business service. - Ensures the business service is validated and meets all defined acceptance criteria before launch. - Delegates responsibilities but not accountabilities. - Becomes the risk owner of service delivery risks affecting the business service. - Becomes the issue owner of service delivery issues affecting the business service.
Business Process Owner	The Business Process Owner is accountable for one or more business processes that execute specific tasks to deliver business services or physical goods. Business processes define the business roles that execute assigned tasks, which in turn can be manual, automated, or a combination of both, required to take inputs and transform them into outputs. The Business Process Owner ensures processes are effective; efficient; properly documented; free from waste, defects, gaps, and overlaps; and collaborate transparently with adjacent processes.	- Owns one or more designated business processes. - Ensures the business process lifecycle is managed efficiently from inception until disposal. - Ensures the business process is effective throughout its lifecycle. - Ensures the business processes deliver the business service or physical goods. - Ensures the business processes are modelled using appropriate industry notations that support manual or automated verification. - Ensures the business process is free from waste, defects, gaps, and overlaps. - Ensures the business process collaborates with adjacent business processes transparently. - Ensures the business process is valued in terms of integrity and availability criticality. - Ensures the business process criticality is identified to support the Business Continuity Plan (BCP). - Ensures the business process has defined business roles with accountabilities and responsibilities. - Ensures the business process complies with relevant regulatory and legal requirements. - Ensures the business processes are validated before transitioning them into operations. - Approves the business process transition into operations. - Approves the changes made to the business process. - Delegates responsibilities but not accountabilities. - Becomes the risk owner of process execution risks affecting the business process. - Becomes the issue owner of process execution issues affecting the business process.

Business Role	Description	Accountability
Business Function Owner	The Business Function Owner is accountable for one or more business functions that develop the competencies of business roles assigned to selected human resources, who in turn execute corresponding business processes. This role focuses on ensuring business roles have the necessary job descriptions, development, training, and awareness to perform their duties effectively. In addition, the Business Function Owner ensures the competencies of business roles are aligned with and support the organisational core competencies.	- Owns one or more designated business functions. - Ensures the business function lifecycle is managed efficiently from inception until disposal. - Ensures the business function is effective throughout its lifecycle. - Ensures business roles have defined job descriptions. - Ensures business roles have appropriate training paths and programmes. - Ensures business roles have required competencies to execute the business processes. - Ensures business roles and competencies comply with relevant regulatory and legal requirements. - Ensures business role holders maintain awareness of relevant organisational policies. - Ensures business role competencies are aligned with and support the organisational core competencies. - Approves the competency levels and corresponding requirements for business roles. - Approves the business function transition into operations. - Approves changes made to the business function. - Delegates responsibilities but not accountabilities. - Becomes the risk owner of competency risks affecting the business function. - Becomes the issue owner of competency issues affecting the business function.

Business Role	Description	Accountability
Information Owner	The Information Owner is accountable for individual information items within an information asset. Information items represent discrete units of information, such as documents, records, individual data entries of a dataset, and underlying files. The Information Owner ensures information items are accurate, valued, appropriately accessible, and compliant with the policies established for their parent information asset.	- Owns one or more designated information items. - Ensures the information item lifecycle is managed from creation or acquisition until disposal. - Ensures the information item is valued in terms of confidentiality, integrity, and availability criticality. - Ensures the information item inherits and reflects the classification level and requirements of its parent information asset, housed in the domain of trust³, and established by the Information Asset Owner. - Ensures the inherited classification level of the information item, from its parent information asset, reflects the results of the information item valuation. - Ensures the information item is placed in the correct information asset repository based on the required level of protection. - Ensures the information item is accurate and up-to-date. - Ensures the information item complies with the Single Source of Truth (SSOT). - Ensures the information item complies with the Single Version of Truth (SVOT). - Ensures the information item complies with the policies established for its parent information asset. - Authorises access to the individual information item within the governance of the parent information asset. - Contributes to the execution of the Security Response Plan (SRP) by assessing risks to specific owned information items and certifying the accuracy and completeness of recovered data. - Ensures the information item is sanitised before it is shared with recipients with a lower classification level than that of the information item. - Delegates responsibilities but not accountabilities. - Becomes the risk owner of risks affecting the information item. - Becomes the issue owner of issues affecting the information item.

³ A conceptual area with a boundary, a level of trust, and entry and exit gates, where entities with similar objectives interact between them to form a community to add value to the organisation.

Business Role	Description	Accountability
Information Asset Owner	The Information Asset Owner is accountable for one or more information assets. These assets may include datasets, databases, data warehouses, or other aggregated information structures. The Information Asset Owner ensures information assets comply with the organisational information governance, are valued, are placed within defined domains of trust with access restricted based on matched trust levels ⁴ and trustworthiness levels ⁵ , and that risks to information assets are treated. Individual items within these assets are owned by Information Owners.	- Owns one or more designated information assets. - Ensures the information asset lifecycle is managed effectively from creation or acquisition until disposal. - Ensures the information asset complies with the organisational information governance. - Ensures the information asset is the Single Source of Truth (SSOT). - Ensures the information asset is the Single Version of Truth (SVOT). - Ensures the information asset complies with relevant regulatory and legal requirements. - Ensures the information asset is valued in terms of confidentiality, integrity, and availability criticality. - Ensures the information asset has its corresponding classification based on its valuation. - Ensures a domain of trust is defined for handling the information asset. - Ensures a level of trust is assigned to the domain of trust. - Ensures the level of trust assigned to the domain of trust is proportionate to the classification level of the information asset and to the aggregation of information, by accumulation and association. - Ensures access to the information asset is restricted to a domain of trust meeting the required trustworthiness level. - Ensures a risk tolerance level is defined and applied to the information asset. - Approves the treatment of risks affecting the information asset. - Authorises access to the information asset. - Ensures each information asset is covered by a Security Response Plan (SRP). - Approves the Security Response Plan (SRP) that covers the owned information asset. - Approves the information asset transition into operations. - Approves the changes made to the information asset. - Ensures the information asset is sanitised before it is shared with recipients with a lower classification level than that of the information asset. - Ensures the information asset is disposed securely. - Delegates responsibilities but not accountabilities. - Becomes the risk owner of risks affecting the information asset or assigns a designated risk owner where Segregation of Duties (SoD) is applicable. - Becomes the issue owner of issues affecting the information asset or assigns a designated issue owner where Segregation of Duties (SoD) is applicable.

⁴ The level of belief, held by a trustor at a defined point in time, that a trustee will deliver the expected behaviour.

⁵ The level of reliance, placed on the trustee at a defined point in time, to deliver the expected behaviour to the trustor.

Business Role	Description	Accountability
System Owner	The System Owner is accountable for one or more IT systems⁶, including system software, middleware software, and application software found in the application domain and infrastructure domain. Application software supports business processes and manages their information and underlying data, while virtual and physical infrastructure hosts these applications and provides the scalability required for business flexibility. Middleware software interconnects application software. The System Owner ensures IT systems remain trustworthy from creation or acquisition to disposal and are aligned with business needs while maintaining a minimal attack surface.	- Owns one or more designated IT systems. - Ensures the IT system lifecycle is managed efficiently from creation or acquisition until disposal. - Ensures the IT system is supported throughout its lifecycle. - Ensures the IT system remains trustworthy throughout its lifecycle in alignment with the required trust levels of the domain of trust. - Ensures the IT system technical debt is identified, tracked, and remediated. - Ensures the IT system aligns with the business processes it supports. - Ensures the IT system complies with relevant regulatory and legal requirements. - Ensures the IT system maintains a minimal footprint and reduced attack surface, and is free of vulnerabilities, throughout its lifecycle. - Ensures the IT system is valued in terms of integrity and availability criticality. - Ensures a risk tolerance level is defined and applied to the IT system. - Approves the treatment of risks affecting the IT system. - Approves the IT system transition into operations. - Approves the changes made to the IT system. - Pre-approves the shutdown of the IT system to contain cyberattacks. - Ensures the IT system has a Disaster Recovery Plan (DRP). - Approves the Disaster Recovery Plan (DRP) of the IT system. - Ensures the IT system is sanitised of all information items before its disposal. - Ensures the IT system is disposed securely. - Delegates responsibilities but not accountabilities. - Becomes the risk owner of risks affecting the IT system or assigns a designated risk owner where Segregation of Duties (SoD) is applicable. - Becomes the issue owner of issues affecting the IT system or assigns a designated issue owner where Segregation of Duties (SoD) is applicable.

⁶ An IT system consists of a software system hosted on a hardware system. Subsets of a software system include system software (e.g., Hypervisor, Operating System), middleware software (e.g., Enterprise Service Bus, Message Broker), and application software (e.g., Human Capital Management).

Business Role	Description	Accountability
Facility Owner	The Facility Owner is accountable for one or more buildings, including offices, datacentres, outlets, warehouses, or other locations where business operations occur. The Facility Owner ensures facilities provide appropriate environmental controls, physical protection, and supporting infrastructure for the IT systems, people, and operations they house, while maintaining business continuity.	- Owns one or more designated physical facilities. - Ensures the facility lifecycle is managed efficiently from acquisition or construction until disposal or lease return. - Ensures the facility provides the essential physical infrastructure required to support the housed IT systems, people, and operations. - Ensures the facility maintains a level of trust proportionate to the level of trust of the domain of trust it belongs to. - Ensures the facility remains compliant with all relevant health, safety, and building regulations. - Approves the layout of the facility to optimise space, safety, and security. - Approves the facility transition into active operations following successful commissioning. - Approves structural changes made to the facility to mitigate unmanaged risks. - Pre-approves the emergency shutdown of utilities or evacuation of the facility to contain physical threats. - Ensures the facility has a Disaster Recovery Plan (DRP). - Approves the Disaster Recovery Plan (DRP) for the facility. - Ensures the facility is physically sanitised before its disposal or lease return. - Delegates responsibilities but not accountabilities. - Becomes the risk owner of risks affecting the facility. - Becomes the issue owner of issues affecting the facility.
Interface Owner	The Interface Owner is accountable for one or more interfaces that enable communication and data exchange between entities within and across the organisation. Interfaces may connect services, business processes, information, IT systems, and buildings, and facilitate information flows. This cross-cutting role ensures interfaces are properly designed, documented, protected, and maintained to enable seamless collaboration, interoperability, and integration within and across organisational boundaries while protecting the domains of trust they connect.	- Owns one or more designated interfaces. - Ensures the interface lifecycle is managed effectively from design or acquisition until decommissioning. - Ensures the interface remains trustworthy and adheres to the levels of trust of the domains of trust it connects. - Ensures the interface supports and maintains data integrity and consistency during exchange. - Ensures the interface is properly documented and maps all interconnected entities across the domains of trust. - Ensures the interface complies with relevant regulatory and legal requirements. - Ensures the interface accurately maps and connects the entities it supports, including business products, business services, business processes, information assets, IT systems, and facilities. - Approves the interface transition into operations. - Approves all changes to the interface. - Pre-approves the suspension of the interface to contain cyberattacks. - Ensures the interface has a Disaster Recovery Plan (DRP). - Approves the Disaster Recovery Plan (DRP) for the interface. - Ensures the interface is securely decommissioned and all active connections are closed and terminated before disposal. - Delegates responsibilities but not accountabilities. - Becomes the risk owner of risks affecting the interface. - Becomes the issue owner of issues affecting the interface.

Business Role	Description	Accountability
Security Control Owner	The Security Control Owner is accountable for one or more security controls that protect organisational assets. Security controls may be embedded in layers (i.e., offering, business, knowledge, application, infrastructure, and facility domains of the structural profile, and interface profile), in tiers (i.e., deterrent, protective, detective, and corrective), and as lines of defence, eventually forming a layered defence. The Security Control Owner ensures security controls are proportionate enabling business objectives protecting the designated assets, remain effective throughout their lifecycle, and are regularly fine-tuned to maintain their protective capability.	- Owns one or more designated security controls. - Ensures the security control lifecycle is managed efficiently from design or acquisition until retirement. - Ensures the security control is supported throughout its lifecycle. - Ensures the security control remains effective throughout its lifecycle in alignment with the required security control objectives. - Ensures the security control is supported throughout its lifecycle. - Ensures security control implementation gaps are identified, tracked, and remediated. - Ensures security debt associated with security control implementation gaps is identified, tracked, and remediated. - Ensures the security control mitigates corresponding identified inherent security risks to acceptable tolerance levels. - Ensures the security control maintains appropriate coverage of identified threats and vulnerabilities. - Ensures the security control complies with relevant regulatory and legal requirements. - Approves the authorised scope and configuration of the security control. - Approves the security control transition into operations. - Approves the changes made to the security control. - Ensures the security control is coherent with the overall layered defence. - Ensures the security control is constantly fine-tuned to maintain effectiveness. - Ensures the security control is decommissioned and retired cleanly before disposal. - Delegates responsibilities but not accountabilities. - Becomes the risk owner of risks affecting the security control effectiveness. - Becomes the issue owner of issues affecting the security control.
Risk Owner	The Risk Owner is accountable for one or more designated risks, ensuring residual risks remain within acceptable tolerance levels through appropriate mitigations. This role is fulfilled by the owner of the affected domain unless a specific Risk Owner is assigned. To maintain Segregation of Duties (SoD), the Risk Owner must be independent from the owner who sets the risk tolerance level.	- Owns one or more designated risks. - Ensures the assigned residual risks remain within the designated level of risk tolerance. - Ensures the mitigations for risks are delivered within their timeframe. - Provides regular updates on mitigation progress and residual risk status to the original delegating owner. - Delegates responsibilities but not accountabilities.

Business Role	Description	Accountability
Issue Owner	The Issue Owner is accountable for one or more designated issues requiring resolution. Issues are risks that have materialised and require immediate attention. This role is fulfilled by the owner of the affected domain unless a specific Issue Owner is assigned. To maintain Segregation of Duties (SoD), the Issue Owner must be independent from the owner who approves the resolution or accepts the residual risk after remediation.	- Owns one or more designated issues. - Ensures issues are resolved within their agreed timeframes to minimise organisational impact. - Provides updates on resolution progress to the original delegating owner. - Ensures the original delegating owner is satisfied that the root cause has been addressed to prevent recurrence. - Delegates responsibilities but not accountabilities.

Table 1. SEF® Lean Version: Accountable Business Roles – Description and Duties

3 BENEFITS

Implementing clear ownership across an organisation generates substantial benefits that span governance, risk management, operational performance, and strategic alignment. The following business benefits are provided:

- A. **Decisive Authority.** When ownership is unambiguously defined, clarity and accountability are established throughout the organisation. In addition, clear lines of authority are established, allowing decisions to be made decisively with explicit ownership of those decisions. Furthermore, organisational performance improves because accountability drives continuous improvement and owners remain answerable for results.
- B. **Enhanced Risk Management.** Owners are positioned to be accountable for identifying, managing, and mitigating risks affecting their assigned domains. Proactive risk mitigation is enabled because owners understand that they will be held accountable for risk management. When issues arise, they are resolved more rapidly because owners drive solutions and accountability prevents delays in decision making. Prevention of recurrence is achieved through root cause analysis undertaken by owners who are accountable for ensuring similar issues do not arise again.
- C. **Effective Governance.** Clear decision making is developed based on ownership, eliminating ambiguity about who decides what. Compliance with regulatory and legal requirements is assigned to accountable owners, ensuring that governance obligations are not overlooked. Audit trails document which owner is accountable for what decisions and outcomes, enabling accountability to be traced and verified.
- D. **Improved Operational Efficiency.** Duplication of effort is reduced because ownership boundaries are clearly defined, preventing multiple parties from performing the same work. Better coordination is enabled as owners understand their interdependencies with other owners and work together to achieve aligned outcomes. Problem resolution is accelerated because owners have the authority and accountability to make decisions rapidly. Resource allocation is optimised because owners can direct resources toward priority outcomes for their domains. These efficiency gains deliver financial benefits through improved Return on Investment (ROI) as operational costs are reduced and resource utilisation improves. Likewise, Total Cost of Ownership (TCO) decreases through elimination of duplication, proactive risk management, and prevention of costly failures.
- E. **Architectural Coherence.** Clear ownership at each organisational level ensures architectural alignment from strategy through execution. Products align with business strategy, business processes optimise delivery, IT systems support those processes, information assets are protected, and security controls form a coherent defence; all because designated owners are accountable for domain alignment and effectiveness.

- F. **Enhanced Scalability and Flexibility.** Clear Clear role definitions enable efficient onboarding of new owners, as their accountabilities are explicit and well documented. Accountability endures through organisational growth because ownership can be distributed without weakening the accountability structure. Ownership may be adapted to suit organisational circumstances without eroding accountability, since the structure itself remains constant. Roles can be adjusted in response to organisational change while the accountability structure is preserved, ensuring that governance endures as the organisation evolves.

GLOSSARY

Glossary	
Term	Description
BCP	Business Continuity Plan
CC	Creative Commons
DRP	Disaster Recovery Plan
ROI	Return on Investment
SEF	Secure Enterprise Framework
SoD	Segregation of Duties
SRP	Security Response Plan
SSOT	Single Source of Truth
SVOT	Single Version of Truth
TCO	Total Cost of Ownership

REFERENCES

BARUTTIS, A. (2020). *SEF® Lean Version* [PDF]. Release 4.0. Technognomi Ltd. Available at: <https://github.com/abaruttis/secure-enterprise-framework-lean>.